Análisis Forense: Proyecto de Aula “Investigadores Forenses por un Día”

AUTOR(ES)

Equipo CSIRT: Cristobal , Gracia, Lorena

FECHA:
07/ 11/ 2025

ÍNDICE

Resumen	3
CASO 1 – Infección por malware con posible criptominero	4
CASO 2 – Intento de acceso no autorizado por fuerza bruta	7
CASO 3 – Ataque de ransomware en la red interna (LockBit 3.0)	10
CASO 4 – Ataque de phishing con descarga de troyano	14

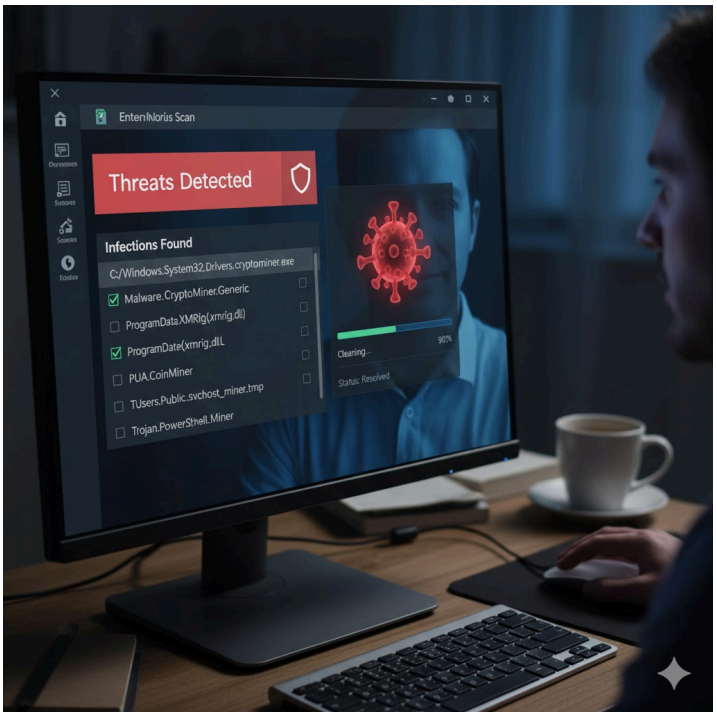
Resumen

Este documento presenta el análisis forense de los cinco casos propuestos en el proyecto de aula 'Investigadores Forenses por un Día'. Cada caso se expone con su título, descripción, cómo se produjo, herramientas utilizadas, acciones de respuesta, y conclusiones/medidas preventivas.

CASO 1 – Infección por malware con posible criptominero

1. Descripción breve del incidente:

Un usuario reporta que su equipo presenta un rendimiento muy bajo. El análisis con el antivirus detecta y elimina varios archivos sospechosos relacionados con minería de criptomonedas.



2. Cómo se produjo y qué vulnerabilidades lo permitieron:

El usuario descargó un software desde una fuente no confiable. El programa contenía un malware que aprovechó la falta de actualizaciones, ausencia de filtros de contenido del sistema operativo y la ausencia de una política de control de descargas.



3. Herramientas utilizadas y resultados clave:

Antivirus: detectó procesos ocultos de minería.

Administrador de tareas y Process Explorer: mostraron uso anómalo de CPU y GPU.

Wireshark: identificó conexiones a servidores de minería externos.



4. Acciones de respuesta aplicadas:

Desconexión temporal del equipo de la red, para contener el ataque.

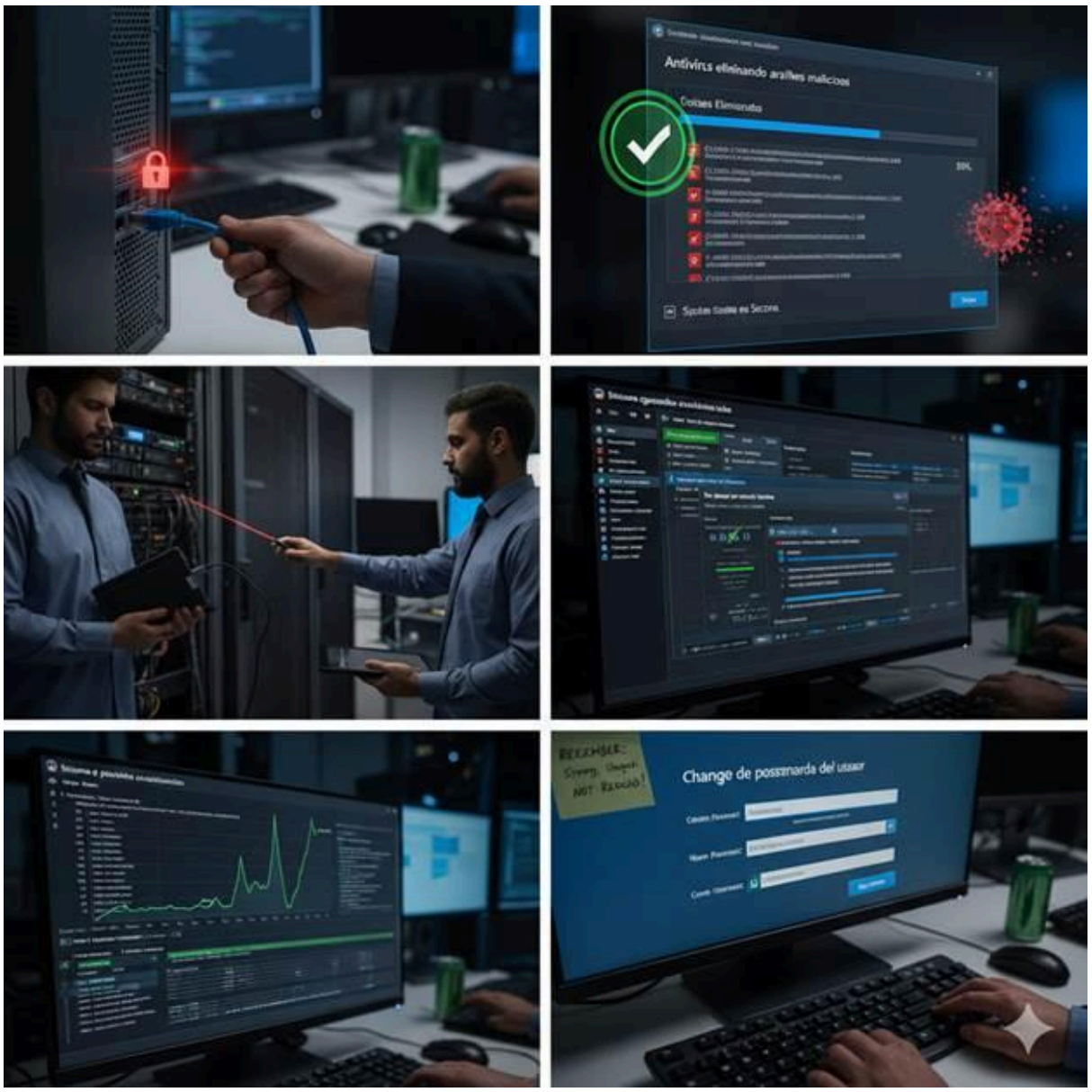
Eliminación de los archivos maliciosos.

En caso de disponer de copias de seguridad limpias, restaurar la última versión.

Actualización/ Escaneo completo del sistema y refuerzo del antivirus.

Revisión de otros equipos en la red.

Cambiar las contraseñas del equipo.



5. Conclusiones y medidas preventivas:

Implementar políticas de descarga segura y restricción de software, mantener los sistemas actualizados, usar herramientas de monitoreo de rendimiento, y reforzar la educación de los usuarios sobre software no autorizado.

CASO 2 – Intento de acceso no autorizado por fuerza bruta

1. Descripción breve del incidente:

El sistema de correo electrónico registró múltiples intentos fallidos de acceso desde direcciones IP extranjeras en un corto período.



2. Cómo se produjo y qué vulnerabilidades lo permitieron:

Los atacantes obtuvieron el correo electrónico del empleado (posiblemente de filtraciones de datos públicas). Utilizaron herramientas automatizadas para probar miles de contraseñas comunes. Emplearon listas de credenciales filtradas de otras brechas (credential stuffing). Rotaron IPs usando VPNs o botnets para evitar bloqueos simples. Realizaron un ataque de fuerza bruta aprovechando contraseñas débiles y la ausencia de un límite de intentos de inicio de sesión. Vulnerabilidades: falta de autenticación multifactor (MFA), contraseñas simples y políticas laxas de bloqueo de cuenta.



3. Herramientas utilizadas y resultados clave:

Logs del servidor de correo: mostraron repetidos intentos fallidos.

SIEM: extrae información de los logs generados por el resto de herramientas.

Suricata: correlacionó eventos y detectó patrón de ataque. Crear reglas para detectar >5 intentos fallidos en 10 minutos.

Geolocalización de IPs: confirmó origen en países no relacionados con la empresa.



4. Acciones de respuesta aplicadas:

Bloqueo de direcciones IP sospechosas por localización.

Reseteo de contraseñas afectadas.

Implementación de MFA y reglas de bloqueo tras varios intentos con Fail2Ban.

Reportar IPs maliciosas.

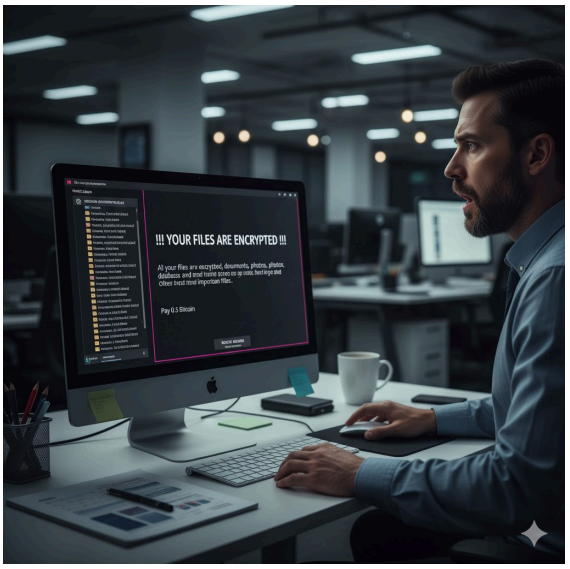
5. Conclusiones y medidas preventivas:

Usar contraseñas robustas, habilitar MFA, monitorear accesos inusuales, y establecer alertas automáticas ante múltiples intentos fallidos.

CASO 3 – Ataque de ransomware en la red interna (LockBit 3.0)

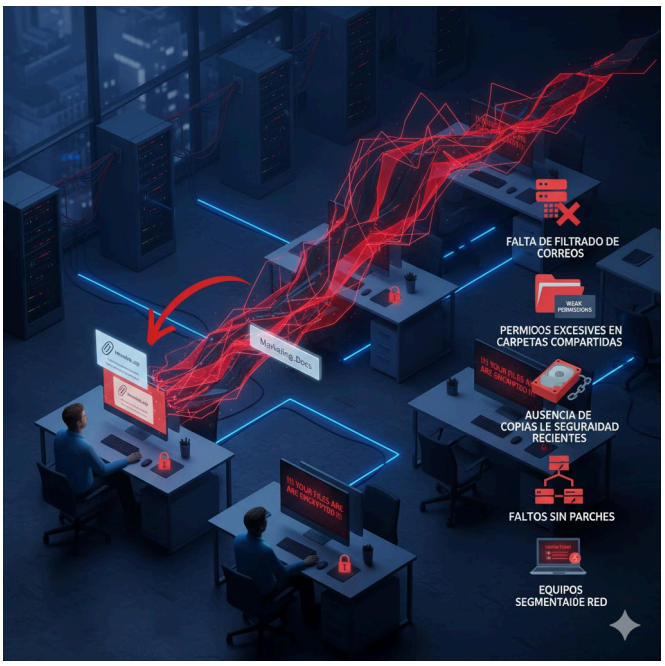
1. Descripción breve del incidente:

Varios empleados reportaron que no podían acceder a sus documentos y que los nombres de los archivos habían cambiado de extensión a '.locked'. En cada carpeta afectada apareció una nota de rescate ('README_RECOVER_FILES.txt') que exigía el pago de 0.5 Bitcoin.



2. Cómo se produjo y qué vulnerabilidades lo permitieron:

Un empleado abrió un archivo adjunto malicioso que ejecutó el ransomware. Este se propagó a través de recursos compartidos con permisos débiles. Vulnerabilidades: falta de filtrado de correos, permisos excesivos en carpetas compartidas, ausencia de copias de seguridad recientes, falta de segmentación de red, equipos sin parches.



Detalles del incidente:

Empleado RRHH abre 'CV_Urgente.zip' con 'candidato.exe'. Ejecutable descarga payload de http://185.231.154.12/encryptor.dll. LockBit 3.0 se inyecta en proceso legítimo lsass.exe. Escaneo de red buscando recursos compartidos SMB. Credential dumping usando Mimikatz variante. Movimiento lateral usando credenciales robadas (15 equipos adicionales comprometidos via SMB). Inicio cifrado masivo en servidor de archivos. Servidor de producción SQL afectado. Detección por EDR por comportamiento anómalo de cifrado. Eliminó copias de seguridad y puntos de restauración. Mostró la nota de rescate.

3. Herramientas utilizadas y resultados clave:

Antivirus / EDR (CrowdStrike Falcon): detectó la actividad de cifrado masivo e identificó la variante del ransomware.

Logs del servidor: mostraron propagación del ejecutable.

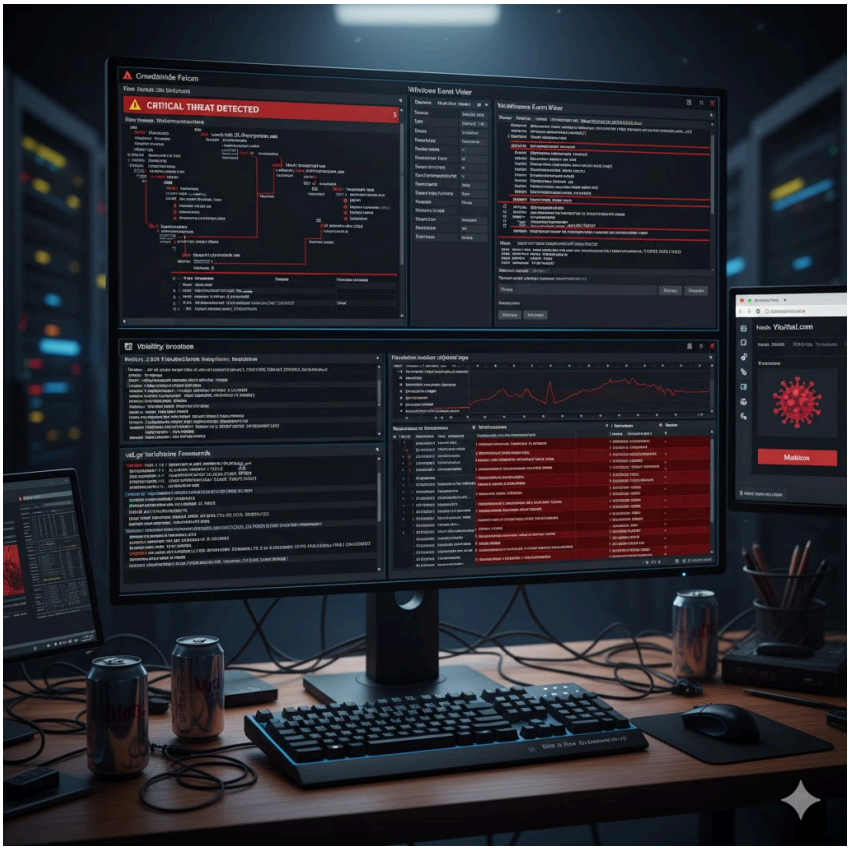
Herramientas forenses (Autopsy, Volatility): analizar la memoria RAM e identificar conexiones con direcciones IP externas (C2).

Logs de Windows y Sysmon: revelaron la propagación del ejecutable 'invoice_reader.exe' a

través de SMB y RDP.

Wireshark: mostró tráfico cifrado hacia un servidor de comando y control.

Hash SHA256 del archivo malicioso: coincidió con muestras previamente reportadas en bases de datos como VirusTotal.



4. Acciones de respuesta aplicadas:

Desconexión inmediata de los equipos infectados de la red LAN.

Reinstalación limpia de los sistemas afectados.

Bloqueo del dominio malicioso en el firewall perimetral y en DNS.

Notificación interna al equipo de TI y al departamento legal.

Reporte del incidente ante el Centro Nacional de Ciberseguridad (INCIBE-CERT) y documentación del evento para auditoría posterior.

Análisis forense de los sistemas comprometidos para identificar el punto de entrada y alcance total del ataque.

5. Conclusiones y medidas preventivas:

Implementar políticas estrictas de copias de seguridad automáticas y almacenamiento fuera de línea (3-2-1). Aplicar segmentación de red y uso de VLANs. Configurar gateway de correo con filtrado antispam y sandboxing. Actualizar y parchear sistemas. Revisar y limitar permisos. Capacitar al personal. Implementar MFA en accesos remotos.

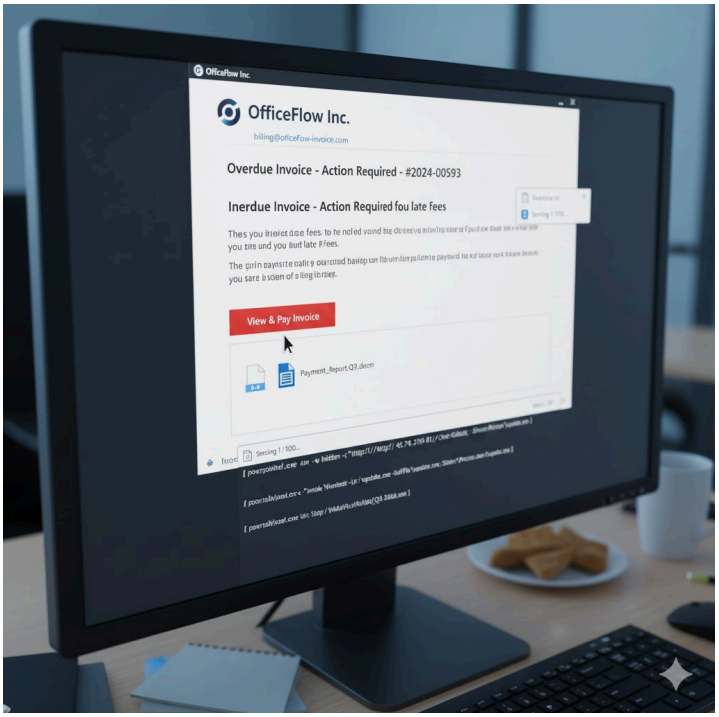
CASO 4 – Ataque de phishing con descarga de troyano

1. Descripción breve del incidente:

Un empleado abre un correo que simula ser una factura legítima. Al hacerlo, su equipo comienza a enviar mensajes automáticos sin su intervención.

2. Cómo se produjo y qué vulnerabilidades lo permitieron:

El usuario cayó en una campaña de phishing con un archivo adjunto infectado. La falta de capacitación en seguridad y la carencia de filtros antispam permitieron la ejecución del malware. Detalles: ingeniería social suplantando a un proveedor, adjunto malicioso (.exe disfrazado, macro de Office o PDF con exploit), macro ejecuta powershell en segundo plano, descarga payload desde http://45.76.218.91/update.exe, Troyano AgentTesla se instala en %AppData% y establece C&C a 45.76.218.91:443.



3. Herramientas utilizadas y resultados clave:

Análisis del correo y adjunto: detectó script malicioso.

Antivirus y EDR: identificaron comportamiento tipo troyano.

Revisión de logs SMTP: mostró envío masivo de correos desde la cuenta comprometida.

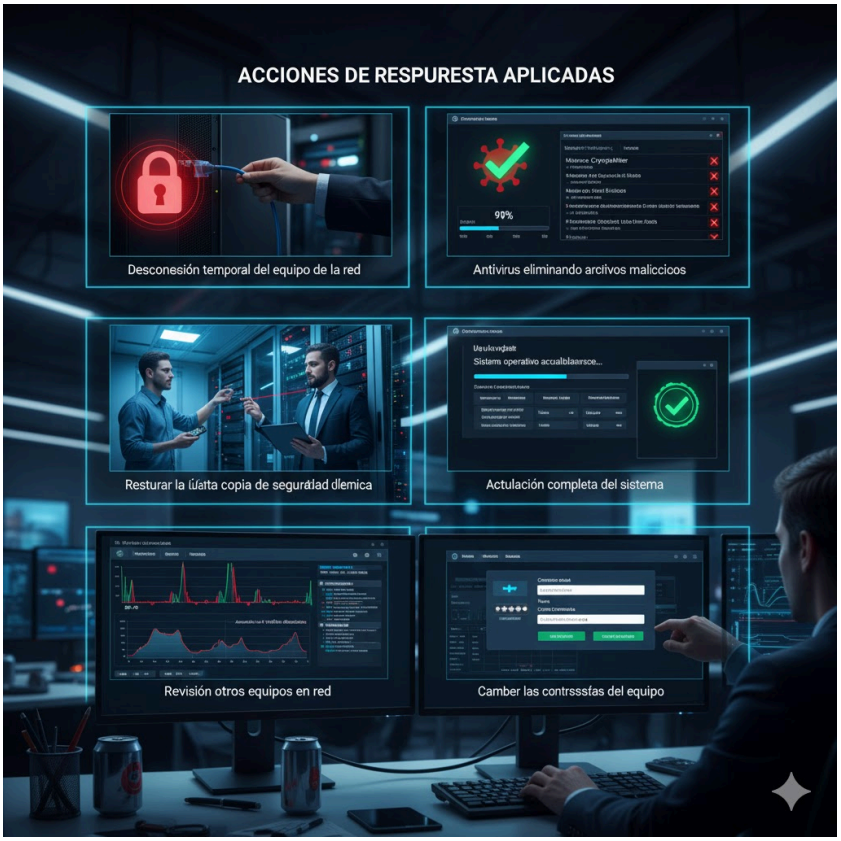
4. Acciones de respuesta aplicadas:

Aislamiento del equipo afectado.

Eliminación del malware.

Restablecimiento de credenciales de correo.

Alerta al resto del personal y bloqueo de remitentes similares.



5. Conclusiones y medidas preventivas:

Capacitar a los empleados en detección de phishing, mantener filtros de correo actualizados, y aplicar políticas de restricción de macros y scripts.

CASO 5 – Ex Filtración Masiva de Datos de Clientes a Servidor Externo No Autorizado

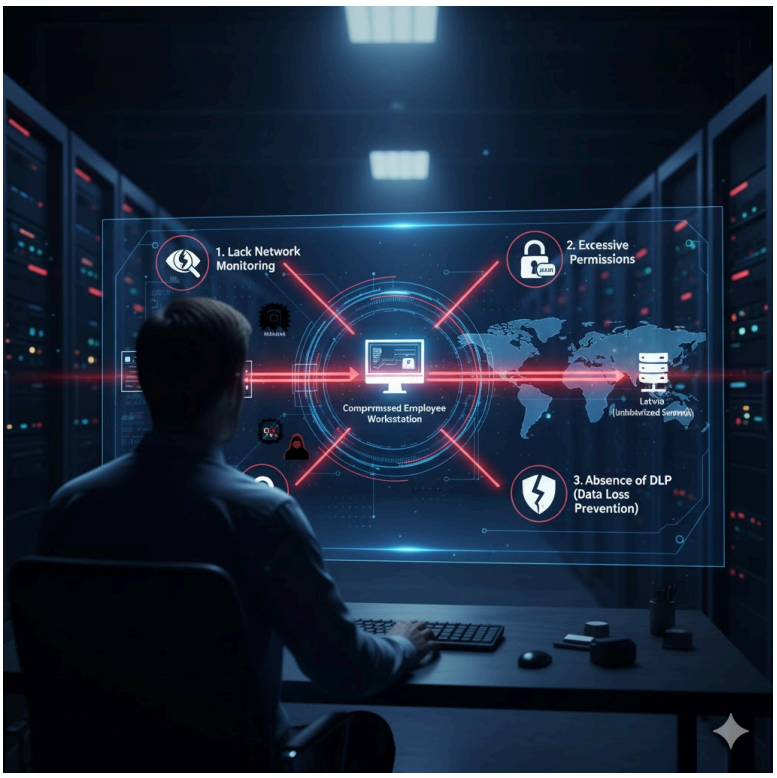
1. Descripción breve del incidente:

Fecha: 15 de marzo de 2024. Horario: 02:15 - 04:30 AM. Duración: 2 horas y 15 minutos. Se detectó tráfico inusual cifrado hacia una IP ubicada en Letonia, con un volumen anómalo de 28.7 GB de datos transmitidos.



2. Cómo se produjo y qué vulnerabilidades lo permitieron:

Un malware instalado en un equipo comprometido recopiló y transmitió datos confidenciales a un servidor remoto. También pudo ser causado por un usuario interno. Vulnerabilidades: falta de monitoreo de red, permisos excesivos, ausencia de DLP.

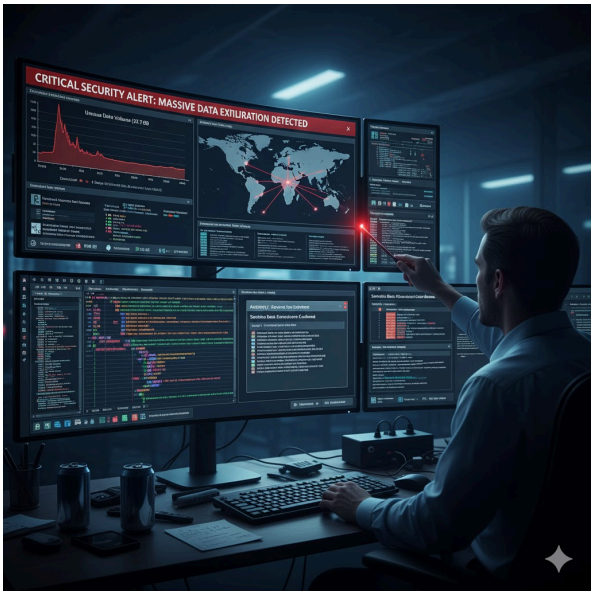


3. Herramientas utilizadas y resultados clave:

Firewall y SIEM: registraron el tráfico inusual.

Wireshark / tcpdump: permitió identificar los paquetes y destino IP.

Herramientas forenses (Autopsy, Volatility): confirmaron la extracción de información sensible.



4. Acciones de respuesta aplicadas:

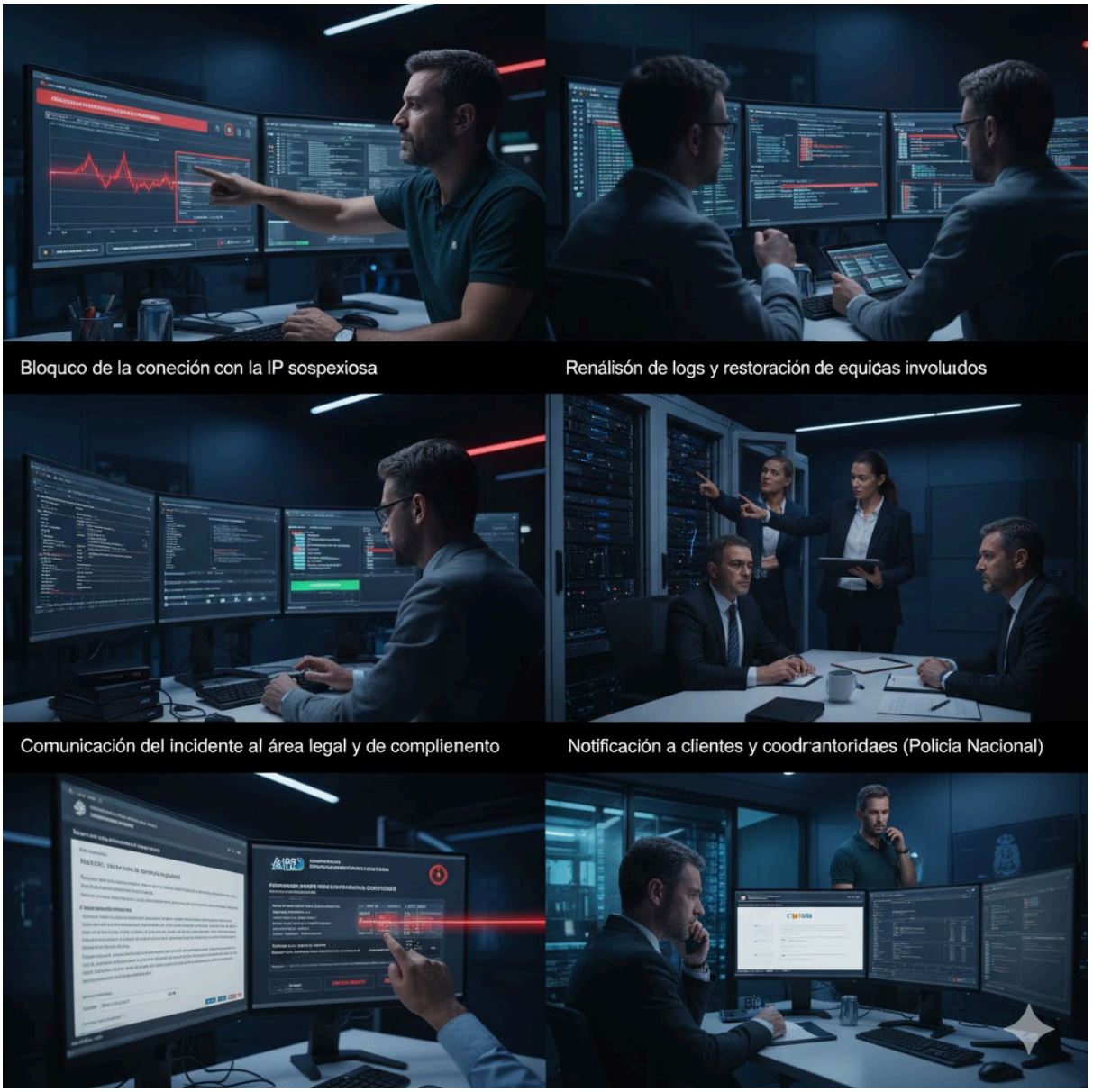
Bloqueo de la conexión con la IP sospechosa.

Análisis de los equipos involucrados.

Revisión de logs y restauración de copias seguras.

Comunicación del incidente al área legal y de cumplimiento. Notificación interna a dirección legal y compliance.

Comunicación regulatoria según LOPD/GDPR (72 horas). Notificación a clientes afectados (45,827 notificaciones). Coordinación con autoridades (INCIBE y Policía Nacional).



5. Conclusiones y medidas preventivas:

Implementar soluciones DLP, segmentar la red, reforzar el control de accesos, monitorear tráfico saliente y concienciar al personal.